

Consent Management Procedures V2.4

Organization: Company A - Saudi Healthcare Authority
Document ID: PDP-PRO-002
Version: 2.4
Classification: INTERNAL
Date: March 15, 2024
Total Pages: 22
Status: APPROVED

DOCUMENT CONTROL

Version	Date	Author	Changes	Approver
1.0	January 10, 2022	Fatima Al-Rashid	Initial document creation	Dr. Ahmed Al-Mansouri
1.5	July 22, 2022	Fatima Al-Rashid	Added PDPL Article 5 requirements	Dr. Ahmed Al-Mansouri
2.0	February 8, 2023	Nora Al-Shamsi	OneTrust CMP integration procedure	Dr. Ahmed Al-Mansouri
2.2	August 30, 2023	Nora Al-Shamsi	Enhanced withdrawal mechanisms	Ibrahim Al-Farsi
2.4	March 15, 2024	Nora Al-Shamsi	Added healthcare-specific consent types	Ibrahim Al-Farsi

Document Owner: Privacy Office
Review Cycle: Annual (Next Review: March 2025)
Distribution: All Departments, IT, Legal, Clinical Services

APPROVAL SIGNATURES

Role	Name	Signature	Date
Chief Privacy Officer	Ibrahim Al-Farsi	[Signed]	March 15, 2024
Chief Legal Officer	Dr. Khalid Al-Otaibi	[Signed]	March 14, 2024
Chief Medical Officer	Dr. Sarah Al-Qahtani	[Signed]	March 13, 2024
IT Director	Mohammed Al-Zahrani	[Signed]	March 12, 2024

TABLE OF CONTENTS

1. OBJECTIVE AND SCOPE	4
2. REGULATORY FRAMEWORK	5
3. CONSENT TYPES AND REQUIREMENTS	7
4. OBTAINING VALID CONSENT	10
5. CONSENT COLLECTION WORKFLOWS	13
6. WITHDRAWING CONSENT	16
7. CONSENT MANAGEMENT PLATFORM (CMP)	18
8. RECORD KEEPING AND AUDIT	20
9. ROLES AND RESPONSIBILITIES	21
APPENDIX A: CONSENT FORM TEMPLATES	22
APPENDIX B: CONSENT DECISION TREE	24

1. OBJECTIVE AND SCOPE

1.1 Purpose

This procedure establishes comprehensive requirements for obtaining, managing, documenting, and withdrawing consent for the collection and processing of personal data in compliance with the Saudi Personal Data Protection Law (PDPL) and NDMO regulations.

1.2 Scope

This procedure applies to:

- All personal data processing activities requiring consent
- Patient healthcare data consent management
- Employee data consent for non-contractual processing
- Marketing and communication preferences
- Research participation consent
- Third-party data sharing consent
- Website and application cookie consent

1.3 Out of Scope

Consent is NOT required under the following legal bases:

- Contractual Necessity: Processing required to fulfill employment or service contracts
- Legal Obligation: Processing mandated by Saudi law (tax records, medical reporting)
- Vital Interest: Emergency medical treatment when consent cannot be obtained
- Public Interest: Government-mandated health initiatives
- Legitimate Interest: Fraud prevention and security monitoring

2. REGULATORY FRAMEWORK

2.1 PDPL Requirements

The Saudi Personal Data Protection Law (Royal Decree M/19, 2021) establishes consent requirements under Article 5:

Article	Requirement	Company A Implementation
Art. 5(1)	Consent must be freely given	No bundled consent; separate checkboxes
Art. 5(2)	Consent must be specific	Granular consent for each purpose
Art. 5(3)	Consent must be informed	Clear privacy notice provided
Art. 5(4)	Consent must be unambiguous	Affirmative action required (opt-in)
Art. 6	Explicit consent for sensitive data	Enhanced consent for health data
Art. 7	Right to withdraw consent	One-click withdrawal mechanism

2.2 NDMO Domain 6 Controls

Control ID	Control Name	Implementation Status
PDP-01	Consent Collection Framework	IMPLEMENTED
PDP-02	Consent Evidence Retention	IMPLEMENTED
PDP-03	Withdrawal Mechanism	IMPLEMENTED
PDP-04	Minor Consent (Parent/Guardian)	IMPLEMENTED
PDP-05	Consent Audit Trail	IMPLEMENTED

2.3 Healthcare-Specific Regulations

Regulation	Requirement	Applicability
CBAHI Standards	Patient consent documentation	All clinical services
MOH Circular 2023/47	Telemedicine consent	Virtual consultations
SFDA Requirements	Clinical trial consent	Research department

3. CONSENT TYPES AND REQUIREMENTS

3.1 Healthcare Consent Categories

3.1.1 Treatment Consent

Element	Requirement
Type	Explicit Written
Validity	Per treatment episode
Language	Arabic (primary), English (secondary)
Witness	Required for surgical procedures
Storage	Patient medical record (Epic EHR)

3.1.2 Health Information Exchange Consent

Element	Requirement
Type	Explicit Written/Electronic
Scope	Sharing with specific healthcare providers
Duration	Until withdrawn or patient transfer
System	Epic Care Everywhere consent module

3.1.3 Research Participation Consent

Element	Requirement
Type	Explicit Written
IRB Approval	Required before consent collection
Cooling-off Period	24 hours minimum
Withdrawal	Without affecting treatment quality

3.2 Administrative Consent Categories

3.2.1 Marketing Communications

Element	Requirement
---------	-------------

Type	Explicit Opt-in
Channels	Email, SMS, WhatsApp (separate)
Frequency Preference	Captured at collection
Default State	Unchecked (no pre-ticked boxes)

3.2.2 Third-Party Data Sharing

Element	Requirement
Type	Explicit Written/Electronic
Third Party Identification	Named entity required
Purpose Limitation	Specific use stated
Duration	Maximum 2 years, renewable

3.2.3 Employee Data Processing

Element	Requirement
Type	Explicit for non-contractual purposes
Scope	Photos, biometrics, performance monitoring
HR System	Oracle HCM consent module

3.3 Digital Consent Categories

3.3.1 Website Cookie Consent

Cookie Type	Legal Basis	Consent Required
Essential	Legitimate Interest	No
Functional	Consent	Yes
Analytics	Consent	Yes
Advertising	Consent	Yes

3.3.2 Mobile Application Consent

Permission	Purpose	Consent Mechanism
Location	Clinic finder	In-app permission + privacy notice
Camera	Document upload	In-app permission

Notifications	Appointment reminders	Explicit opt-in
---------------	-----------------------	-----------------

4. OBTAINING VALID CONSENT

4.1 Consent Validity Criteria

All consent must meet the following four criteria per PDPL Article 5:

4.1.1 Freely Given

- Definition: Individual has genuine free choice; no detriment for refusing
- Prohibited Practices:
 - Bundling consent with service access ("Agree to marketing or cannot register")
 - Power imbalance exploitation (employer over employee)
 - Financial incentives that unduly influence decision
- Validation Check: Review consent form for bundling language

4.1.2 Specific

- Definition: Consent covers defined, explicit, and legitimate purposes
- Requirements:
 - Separate consent for each processing purpose
 - No blanket "I agree to everything" options
 - Granular controls for different data types
- Implementation: OneTrust preference center with purpose toggles

4.1.3 Informed

- Definition: Individual understands what they are consenting to
- Information Required:
 - Identity of the data controller (Company A)
 - Contact details of Privacy Office
 - Purpose(s) of processing
 - Categories of data collected
 - Recipients or categories of recipients
 - Retention periods
 - Rights available (access, correction, deletion, withdrawal)
- Delivery: Privacy notice hyperlink at point of consent

4.1.4 Unambiguous

- Definition: Clear affirmative action indicating agreement
- Valid Actions:
 - Ticking an unchecked box

- Clicking "I Consent" button
- Signing a paper form
- Verbal consent (recorded and documented)
- Invalid Actions:
 - Pre-ticked boxes
 - Silence or inaction
 - Scrolling past notice
 - "By continuing to use this site..."

4.2 Language Requirements

Audience	Primary Language	Secondary Language
Patients (Saudi)	Arabic	English
Patients (Expat)	English	Arabic
Employees	Arabic	English
Website Visitors	Detected by GeoIP	Toggle available

4.3 Accessibility Requirements

All consent mechanisms must be accessible:

- WCAG 2.1 AA compliance for digital forms
- Large print versions available (16pt minimum)
- Screen reader compatible (ARIA labels)
- Audio consent option for visually impaired
- Sign language interpreter for hearing impaired (in-person)

5. CONSENT COLLECTION WORKFLOWS

5.1 Patient Registration Consent Flow

Step 1: Patient arrives at Registration Desk



Step 2: Registration Officer explains consent requirements



Step 3: Patient receives Privacy Notice (Arabic/English)



Step 4: Patient reviews notice (minimum 5 minutes)



Step 5: Patient signs Consent Form (Form PDP-CF-001)



Step 6: Registration Officer scans form to Epic EHR



Step 7: System records: Timestamp, Staff ID, Form Version



Step 8: Patient receives copy of signed consent

5.2 Online Portal Consent Flow

Step 1: User initiates account registration



Step 2: System displays Privacy Notice (full text)



Step 3: User scrolls to bottom (scroll tracking)



Step 4: User checks consent boxes (granular options):

■ I consent to account creation and authentication

■ I consent to appointment reminders via SMS

■ I consent to health tips via email

■ I consent to satisfaction surveys



Step 5: User clicks "Create Account"



Step 6: OneTrust records: User ID, IP, Timestamp, Notice Version



Step 7: Confirmation email sent with consent receipt

5.3 Telemedicine Consent Flow

Step 1: Patient logs into telemedicine portal



Step 2: System displays telemedicine-specific consent



Step 3: Patient reviews:

- Limitations of virtual examination

- Recording consent (if applicable)

- Emergency escalation procedures



Step 4: Patient clicks "I Understand and Consent"



Step 5: Video consultation enabled



Step 6: Consent linked to encounter record

5.4 Research Consent Flow

Step 1: Researcher identifies eligible participant

↓

Step 2: IRB-approved consent form provided

↓

Step 3: Participant has 24-hour cooling-off period

↓

Step 4: Researcher answers questions (documented)

↓

Step 5: Participant signs consent (witnessed)

↓

Step 6: Copy provided to participant

↓

Step 7: Original stored in research file

↓

Step 8: Entry made in Research Consent Register

6. WITHDRAWING CONSENT

6.1 Right to Withdraw

Under PDPL Article 7, individuals have the absolute right to withdraw consent at any time. Withdrawal must be:

- As easy as giving consent
- Without requiring explanation
- Without adverse consequences

6.2 Withdrawal Mechanisms

Channel	Method	Processing Time
Patient Portal	"Manage Preferences" → Uncheck	Immediate
OneTrust Banner	"Withdraw Consent" button	Immediate
Email	Reply "UNSUBSCRIBE"	2 business days
Phone	Call 800-XXX-XXXX	2 business days
In-Person	Complete Form PDP-WF-001	2 business days
Privacy Request Portal	Submit withdrawal request	5 business days

6.3 Withdrawal Processing Workflow

Step 1: Withdrawal request received

↓

Step 2: Verify identity (Knowledge-Based Authentication)

↓

Step 3: Log request in OneTrust DSAR module

↓

Step 4: Update consent status in all systems:

- OneTrust CMP
- Epic EHR (if applicable)
- Oracle HCM (if applicable)
- Marketing automation (HubSpot)

↓

Step 5: Cease processing within 24 hours

↓

Step 6: Send confirmation to individual

↓

Step 7: Document in consent audit trail

6.4 Post-Withdrawal Actions

Consent Type	Action After Withdrawal
Marketing	Remove from all campaigns immediately
Research	Cease data collection; prior data retained per pro
HIE Sharing	Revoke access in Epic Care Everywhere
Analytics	Anonymize historical data

6.5 Exceptions to Withdrawal

Withdrawal does not affect:

- Processing completed before withdrawal
- Legal obligations requiring continued processing
- Data required for ongoing treatment (duty of care)

7. CONSENT MANAGEMENT PLATFORM (CMP)

7.1 OneTrust Implementation

Company A utilizes OneTrust as the centralized Consent Management Platform:

Module	Function	Users
Cookie Consent	Website banner management	50,000+ monthly visitors
Preference Center	Marketing consent management	120,000 patients
Universal Consent	Cross-system consent orchestration	All departments
Mobile SDK	In-app consent	45,000 app users

7.2 Cookie Banner Configuration

Setting	Value
Geo-targeting	Saudi Arabia (KSA)
Language	Arabic (default), English toggle
Layout	Bottom banner, expandable
Colors	Company A branding (Blue/White)
Buttons	"Accept All", "Reject All", "Customize"
Re-consent Trigger	Privacy notice version change

7.3 Preference Center Categories

Category	Description	Default
Essential Communications	Appointment confirmations, billing	Always On
Health Reminders	Medication reminders, check-up alerts	Opt-in
Educational Content	Health tips, wellness newsletters	Opt-in
Satisfaction Surveys	Post-visit feedback requests	Opt-in
Research Opportunities	Clinical trial invitations	Opt-in
Partner Communications	Third-party healthcare offers	Opt-in

7.4 Integration Architecture



[REDACTED]

■

[illegible]

■ ■ ■

▼ ▼ ▼

[illegible]

■ Epic EHR ■ ■ Oracle HCM ■ ■ HubSpot ■

■(Patient Data) ■ ■(Employee Data)■ ■ (Marketing) ■

7.5 API Integration

System	Integration Method	Sync Frequency
Epic EHR	HL7 FHIR R4 API	Real-time
Oracle HCM	REST API	Hourly
HubSpot	Native Connector	Real-time
Website	OneTrust JavaScript SDK	Real-time
Mobile App	OneTrust Mobile SDK	Real-time

8. RECORD KEEPING AND AUDIT

8.1 Consent Evidence Retention

All consent records must be retained as evidence of compliance:

Data Element	Storage Location	Retention Period
Consent timestamp	OneTrust + System of Record	7 years after withdrawal
IP address (digital)	OneTrust	7 years
Privacy notice version	Document management	Indefinite
User agent (browser)	OneTrust	7 years
Consent form (scanned)	Epic EHR / SharePoint	Patient lifetime + 10 years

8.2 Audit Trail Requirements

Every consent action must generate an immutable audit log:

```
json
{
  "event_id": "CNS-2024-0047823",
  "event_type": "CONSENT_GRANTED",
  "timestamp": "2024-03-15T09:32:17+03:00",
  "subject_id": "PAT-123456",
  "purpose": "MARKETING_EMAIL",
  "notice_version": "PN-2024-v3.2",
  "collection_point": "PATIENT_PORTAL",
  "ip_address": "10.15.xxx.xxx",
  "user_agent": "Mozilla/5.0...",
  "staff_id": null,
  "evidence_url": "s3://consent-evidence/CNS-2024-0047823.pdf"
}
```

8.3 Audit Schedule

Audit Type	Frequency	Auditor	Scope
Consent collection compliance	Monthly	Privacy Office	Sample of 100 consents
CMP configuration review	Quarterly	IT Security	All OneTrust settings
Withdrawal mechanism testing	Quarterly	Privacy Office	All channels
Full consent audit	Annually	Internal Audit	End-to-end process
External audit	Annually	Deloitte	NDMO compliance

9. ROLES AND RESPONSIBILITIES

9.1 Responsibility Matrix

Role	Responsibilities
Chief Privacy Officer	Overall consent framework governance; policy appro
Privacy Office	Procedure development; training; audit coordinatio
Department Heads	Ensure staff compliance; escalate issues
Registration Staff	Collect patient consent; scan forms
IT Department	CMP administration; integration maintenance
Legal Department	Consent form review; regulatory interpretation
Internal Audit	Independent consent compliance audits

9.2 Training Requirements

Role	Training	Frequency
All Staff	Consent awareness	Annual
Registration Staff	Consent collection procedures	Initial + Annual
Privacy Champions	Advanced consent management	Bi-annual
IT Administrators	OneTrust administration	Initial + Major updates

APPENDIX A: CONSENT FORM TEMPLATES

Form PDP-CF-001: General Patient Consent

COMPANY A - PATIENT CONSENT FOR DATA PROCESSING

Patient Name: _____ MRN: _____

I, the undersigned, hereby consent to Company A collecting and processing my personal data for the following purposes:

- Treatment: To provide healthcare services and maintain my medical record
- Appointment Reminders: To send SMS/email reminders for appointments
- Health Information Exchange: To share my records with referring physicians
- Quality Improvement: To use anonymized data for service improvement
- Marketing: To receive health tips and service announcements

I confirm that I have:

- Received and read the Privacy Notice
- Understood my rights including the right to withdraw consent
- Had the opportunity to ask questions

Signature: _____ Date: _____

Witness (Staff): _____ Employee ID: _____

Form PDP-WF-001: Consent Withdrawal Request

COMPANY A - CONSENT WITHDRAWAL REQUEST

11

YES NO



EXPLICIT CONSENT STANDARD CONSENT
(Written/Signed) (Electronic OK)

Document End

Privacy Office

Company A - Saudi Healthcare Authority

Email: privacy@companya.gov.sa

Hotline: 800-123-4567

Version 2.4 | March 2024